

# Access Control Policy

Versione: 1.0

**Responsabile del documento:** Chief Information Security Officer (CISO)

**Approvata da:** Board of Directors

Frequenza di revisione: Annuale

Data di efficacia: 19/08/2026

## 1. Purpose and Scope

La presente **Access Control Policy** definisce i requisiti per la gestione degli accessi logici ai sistemi, alle applicazioni e alle informazioni di Finaxa.

L'obiettivo è garantire che gli accessi siano autorizzati, tracciabili e limitati alle effettive necessità lavorative, applicando i principi di **least privilege** e **need-to-know**. La policy contribuisce a ridurre il rischio di accessi non autorizzati, abuso di privilegi, compromissione degli account e perdita di riservatezza, integrità o disponibilità delle informazioni.

La policy si applica a dipendenti, collaboratori esterni, consulenti, contractor, fornitori e altri utenti autorizzati. Il perimetro comprende sistemi **on-premise**, ambienti cloud, applicazioni SaaS, sistemi finanziari e di pagamento, database, endpoint aziendali, servizi di accesso remoto e qualsiasi altro sistema utilizzato per trattare informazioni aziendali o dei clienti.

## 2. Policy statements

### 2.1 Least Privilege

Gli accessi ai sistemi, alle applicazioni e ai dati devono essere concessi esclusivamente sulla base di una necessità lavorativa autorizzata. Ogni utente deve disporre dei privilegi minimi necessari allo svolgimento delle proprie responsabilità.

### 2.2 Multi-Factor Authentication

La **Multi-Factor Authentication (MFA)** deve essere applicata agli accessi remoti, agli account privilegiati, ai sistemi critici e agli ambienti che trattano dati di pagamento, inclusi i sistemi appartenenti al **Cardholder Data Environment (CDE)**.

### 2.3 Privileged Access

Gli account privilegiati devono essere separati dagli account standard utilizzati per attività quotidiane. Gli account amministrativi devono essere utilizzati esclusivamente per attività autorizzate che richiedono privilegi elevati.

### 2.4 Shared and Generic Accounts

Gli account condivisi, generici o non nominativi sono vietati, salvo presenza di una necessità aziendale documentata e formalmente approvata. Le eventuali eccezioni devono essere soggette a logging, monitoraggio e ownership definita.

### 2.5 Access Reviews

Gli accessi privilegiati devono essere revisionati almeno **trimestralmente**, mentre gli accessi standard devono essere revisionati almeno **annualmente**. Le revisioni devono essere documentate e gli accessi non più necessari devono essere rimossi tempestivamente.

### 2.6 Joiner-Mover-Leaver

La creazione, modifica e revoca degli accessi deve essere gestita attraverso un processo documentato di **Joiner-Mover-Leaver (JML)**. In caso di cessazione ordinaria, gli accessi devono essere revocati entro quattro ore dalla termination. In caso di cessazione involontaria o situazione ad alto rischio, la revoca deve essere immediata.

### 2.7 Third-Party Access

Gli accessi concessi a fornitori e terze parti devono essere autorizzati, limitati al minimo necessario e, ove possibile, avere una scadenza definita. Gli accessi a sistemi critici devono essere protetti tramite MFA, sottoposti a logging e monitoraggio e revocati al termine dell'attività autorizzata.

## 3. Procedures

La conformità alla presente policy deve essere supportata da processi documentati di **Identity and Access Management (IAM)**. Ogni richiesta di accesso deve essere associata a una necessità aziendale, tracciata attraverso un sistema autorizzato e approvata dal manager dell'utente o dal **System Owner** competente prima del provisioning.

Il processo JML deve garantire che i nuovi utenti ricevano accessi coerenti con il proprio ruolo, che gli accessi vengano aggiornati in caso di trasferimento o modifica delle responsabilità e che quelli non più necessari siano tempestivamente revocati.

I **System Owner** devono effettuare le access review secondo le frequenze stabilite e documentarne l'esito. I log relativi agli accessi privilegiati, remoti e ai sistemi critici devono essere monitorati per identificare attività anomale o non autorizzate. Le evidenze relative a richieste, approvazioni, revisioni e revoche devono essere conservate secondo i requisiti aziendali di audit e compliance.

## 4. Roles and Responsibilities

Il **CISO** è owner della presente policy, definisce i requisiti di access control e supervisiona i rischi significativi relativi alla gestione degli accessi.

L'**IT Security Team** implementa e monitora i controlli di sicurezza relativi ad autenticazione, MFA, privileged access e attività sospette.

La funzione **IT/IAM** gestisce provisioning, modifica e revoca degli account secondo i processi approvati e mantiene le relative evidenze.

I **System Owner** approvano gli accessi ai sistemi di propria competenza e sono responsabili delle relative access review.

I **Line Manager** devono richiedere accessi coerenti con le responsabilità del personale e comunicare tempestivamente cambi di ruolo o termination.

Tutti gli **utenti** sono responsabili della protezione delle proprie credenziali, del corretto utilizzo degli accessi assegnati e della segnalazione di attività sospette.

Le **terze parti** devono rispettare i requisiti di sicurezza e access control definiti nei contratti e negli accordi applicabili.

## 5. Exceptions Process

Qualsiasi eccezione alla presente policy deve essere formalmente documentata e giustificata da una necessità aziendale. La richiesta deve indicare il requisito non rispettato, i sistemi o dati interessati, il rischio associato, la durata richiesta e gli eventuali **compensating controls**.

Le eccezioni devono essere sottoposte a valutazione del rischio e approvate dal CISO o dall'autorità designata. Le eccezioni che comportano un rischio elevato o critico devono essere sottoposte al Risk Management e, quando necessario, al senior management per l'accettazione formale del rischio.

Ogni eccezione approvata deve avere una data di scadenza, essere registrata e sottoposta a revisione periodica. Alla scadenza deve essere chiusa oppure nuovamente valutata e approvata.

## 6. Compliance and Enforcement

Il rispetto della presente policy è obbligatorio per tutti gli utenti che accedono ai sistemi, ai dati e ai servizi di Finaxa. I requisiti di access control devono essere applicati in coerenza con gli obblighi normativi e di sicurezza applicabili all'organizzazione, inclusi **GDPR, UK GDPR, PCI DSS e DORA**, nonché con le policy interne di Finaxa.

La mancata conformità può comportare, in funzione della gravità, limitazione o revoca degli accessi, azioni disciplinari, investigazioni interne, escalation al management o azioni contrattuali nei confronti delle terze parti. Le violazioni che comportano potenziali data breach o compromissioni di sistemi critici devono essere gestite secondo la **Incident Response Policy**.

## 7. Review Cycle

La presente policy deve essere revisionata almeno **annualmente** dal CISO, con il supporto delle funzioni interessate. Una revisione straordinaria deve essere effettuata in seguito a incidenti significativi, audit finding rilevanti, modifiche normative o cambiamenti sostanziali dell'ambiente tecnologico o del profilo di rischio di Finaxa.

Ogni aggiornamento deve essere documentato tramite controllo di versione e le modifiche significative devono essere comunicate agli stakeholder interessati.

## 8. Related Documents

La presente **Access Control Policy** è subordinata alla **Information Security Policy** di Finaxa e deve essere applicata congiuntamente, ove pertinente, alla **Data Classification and Handling Policy, Incident Response Policy, Third-Party Risk Management Policy, Acceptable Use Policy e Business Continuity and Disaster Recovery Policy**.